BAĞ KARAR PANOSU

Bulut Bilişim ve Siber Güvenlik Raporu

Canlı uygulama: https://bag-karar-panosu.pages.dev
Kaynak kod: https://github.com/hsnckrdg/bag-karar-panosu
Bulut platformu: Cloudflare
Dış veri servisi: Open-Meteo
Tarih: 29 Ekim 2026

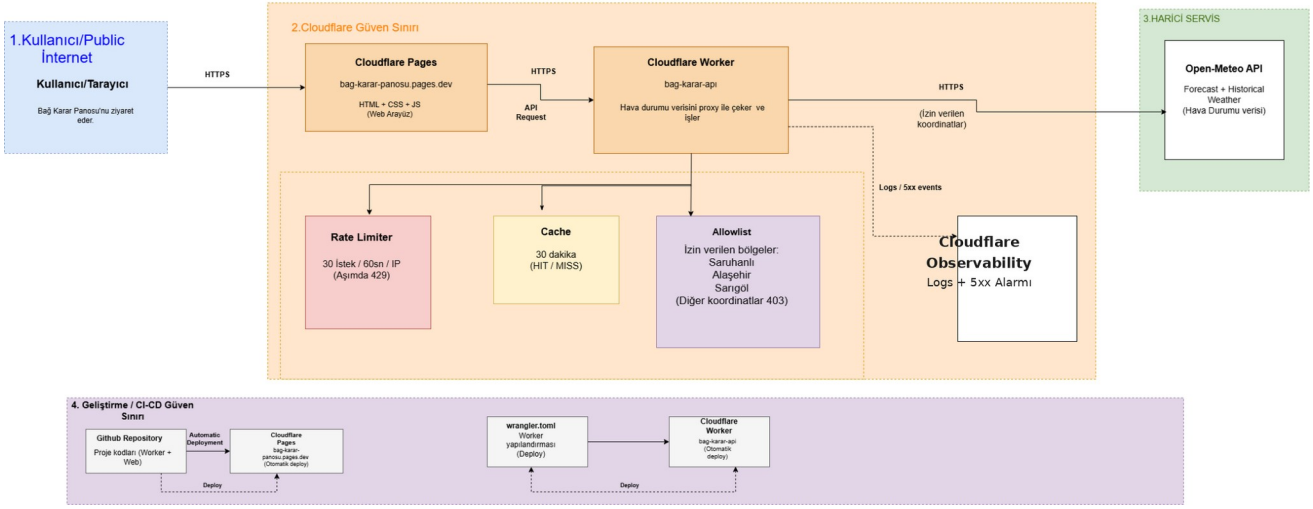
Özet Sonuçlar

- API proxy: koordinat allowlist + 30 istek/60 sn/IP rate limit + 30 dk cache
- k6 testi: 200 isteğin 169 adedi HTTP 429 ile engellendi
- Yetkisiz koordinat: HTTP 403 / LOCATION_NOT_ALLOWED
- SecurityHeaders.com: A+ | MDN HTTP Observatory: A+ (135/100)
- OWASP ZAP: 12 uyarıdan 8 uyarıya düşüş
- Workers loglama, 5xx alarmı ve 1 USD maliyet alarmı etkin

Amaç: 0 TL hedef maliyetle izlenebilir, sınırlandırılmış ve güvenli bir bulut mimarisi oluşturmak.

1. Sistem Mimarisi ve Güven Sınırları

Bağ Karar Panosu dört ana güven alanından oluşmaktadır: kullanıcı/public internet, Cloudflare güven sınırı, harici Open-Meteo servisi ve GitHub tabanlı geliştirme/CI-CD alanı. Kullanıcı HTTPS üzerinden Cloudflare Pages arayüzüne erişir; frontend hava durumu isteklerini doğrudan dış servise değil Cloudflare Worker API proxy katmanına gönderir.



Şekil 1. Bağ Karar Panosu bulut ve güvenlik mimarisi.

Worker katmanında üç temel kontrol bulunur:

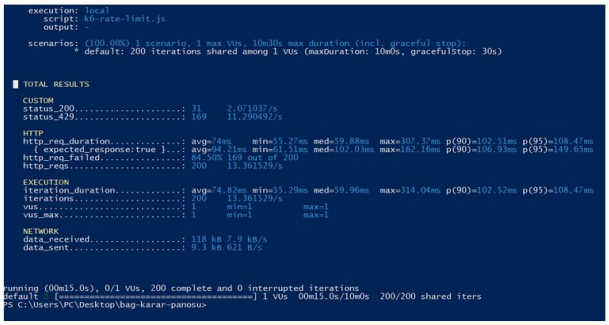
- Rate Limiter: IP başına 60 saniyede en fazla 30 istek; aşımda HTTP 429.
- Cache: aynı verinin 30 dakika boyunca tekrar kullanılmasını sağlar (HIT/MISS).
- Allowlist: yalnızca Saruhanlı, Alaşehir ve Sarıgöl koordinatları kabul edilir; diğerleri HTTP 403 ile reddedilir.

Cloudflare Observability, gerçek API çağrılarını ve hataları izlemek için kullanılır. GitHub tarafında branch protection, pull request akışı, güvenlik kontrolleri ve IaC için wrangler.toml dosyası kullanılmıştır.

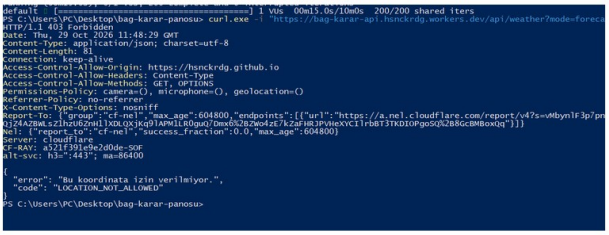
2. API Proxy Güvenliği ve Doğrulama Testleri

Kişiselleştirilmiş ana tehdit açık API proxy kötüye kullanımıdır. Kontroller yalnızca tasarım düzeyinde bırakılmamış, kendi Worker endpoint'i üzerinde doğrulanmıştır. Üç temel test aşağıda tek kanıt grubunda gösterilmiştir.

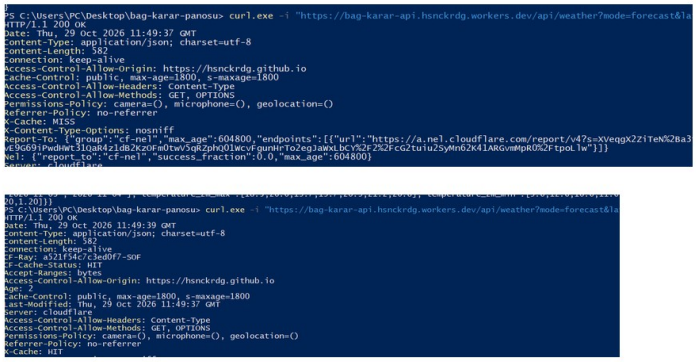
A) k6: 200 istek / 169 adet HTTP 429



B) Allowlist: HTTP 403



C) Cache: ilk istek X-Cache: MISS, ikinci istek X-Cache: HIT



Şekil 2. Rate limit, koordinat allowlist ve cache doğrulama kanıtları.

Sonuç: k6 ile 200 istek gönderilmiş; 31 istek HTTP 200, 169 istek HTTP 429 olarak sonuçlanmıştır. İzin verilmeyen 40/29 koordinatı HTTP 403 ve LOCATION_NOT_ALLOWED koduyla reddedilmiştir. Aynı izinli sorgunun ilk çağrısında X-Cache: MISS, ikinci çağrısında X-Cache: HIT görülmüştür.

3. STRIDE Tehdit Modeli

Sistem bileşenleri STRIDE yaklaşımıyla değerlendirilmiş; her tehdit için olasılık, etki, kontrol ve kalan risk belirlenmiştir.

#	STRIDE	Tehdit	Olasılık	Etki	Kontrol	Kalan risk
1	Spoofing	Sahte/otomatik istemcinin API proxy kullanması	Orta	Orta	HTTPS + IP rate limit	Düşük
2	Tampering	Koordinat parametrelerinin değiştirilmesi	Yüksek	Yüksek	Koordinat allowlist	Düşük
3	Repudiation	Kötü niyetli isteğin sonradan inkârı	Orta	Orta	Workers Logs	Düşük
4	Information Disclosure	Sistem bilgisinin gereksiz açığa çıkması	Düşük	Orta	CSP + HTTPS + güvenlik başlıkları	Düşük
5	Denial of Service	Open API proxy abuse / aşırı trafik	Yüksek	Yüksek	30/60 rate limit + 429 + 30 dk cache	Orta
6	Elevation of Privilege	CI/CD sürecinde gereğinden fazla yetki	Orta	Yüksek	contents: read + branch protection	Düşük
7	Tampering	Frontend/Worker kodunun yetkisiz değiştirilmesi	Orta	Yüksek	PR + Security Checks	Düşük
8	Information Disclosure	Secret/token bilgisinin repoya sızması	Orta	Yüksek	Secret/Push Protection	Düşük

3.1 Kişiselleştirilmiş Tehdit: Open API Proxy Abuse

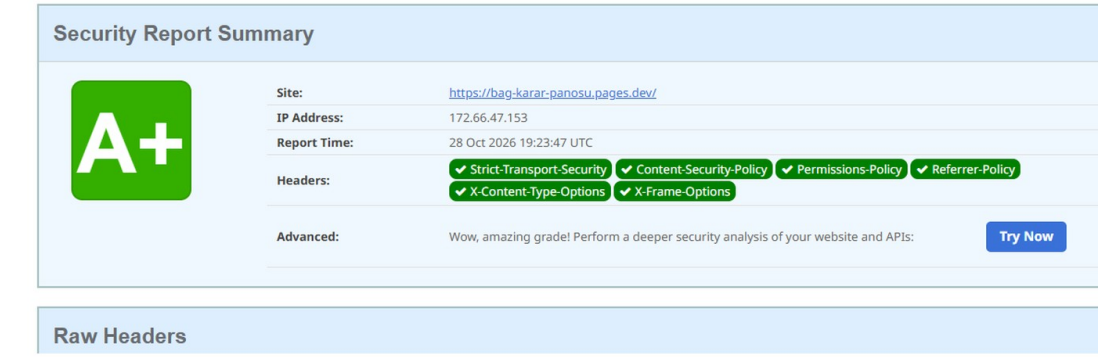
En kritik senaryoda saldırgan, açık proxy'ye yüksek hacimli istek göndererek kaynak tüketimini ve dış servis trafiğini artırabilir. Bu nedenle savunma katmanlı kurulmuştur: (1) yalnızca üç ilçenin koordinatları allowlist ile kabul edilir, (2) IP başına 30 istek/60 saniye sınırı aşılırsa 429 döner, (3) aynı cevap 30 dakika cache üzerinden sunulur. Bu kontrollerden sonra risk tamamen sıfırlanmasa da kalan risk Orta olarak değerlendirilmiştir.

Secret sızıntısı senaryosu için ayrıca "tespit → iptal → yenile → incele → bildir" akışını içeren 1 sayfalık olay müdahale planı hazırlanmıştır.

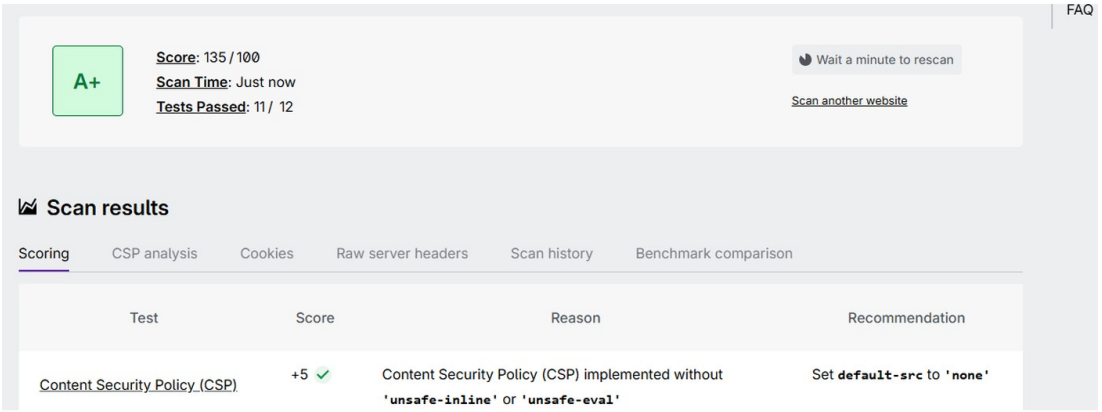
4. Web Uygulaması Güvenliği

Cloudflare Pages üzerindeki final yayında CSP, HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy, Cross-Origin-Opener-Policy ve Cross-Origin-Resource-Policy başlıkları uygulanmıştır. CSP içinde unsafe-inline ve unsafe-eval kullanılmamıştır. Ayrıca /.well-known/security.txt dosyası yayınlanmıştır.

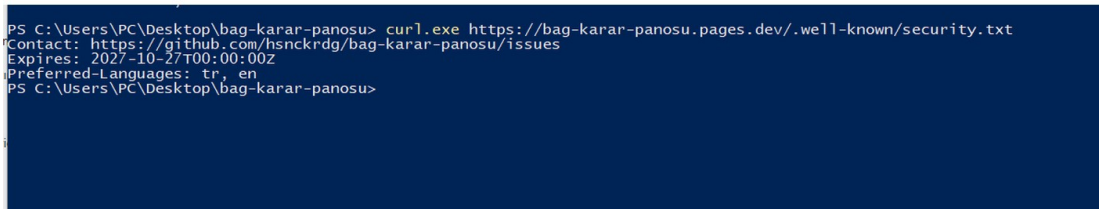
A) SecurityHeaders.com: A+



B) MDN HTTP Observatory: A+ / 135 puan



C) /.well-known/security.txt erişim kanıtı



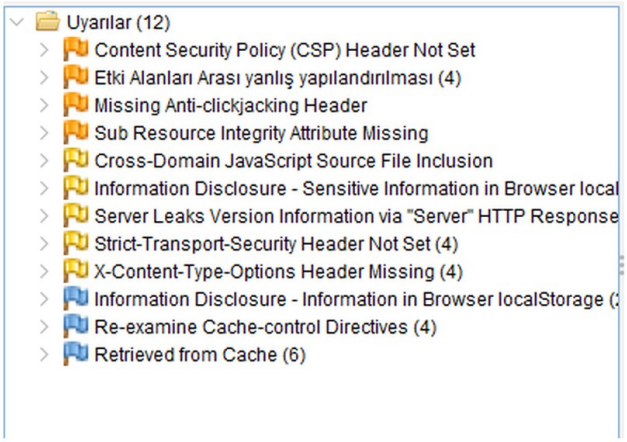
Şekil 3. A+ güvenlik testleri ve security.txt erişim kanıtı.

SecurityHeaders.com sonucu A+; MDN HTTP Observatory sonucu A+ ve 135/100 puandır. Bu sonuçlar ödevdeki SecurityHeaders >= A ve Observatory >= B+ hedeflerini aşmaktadır.

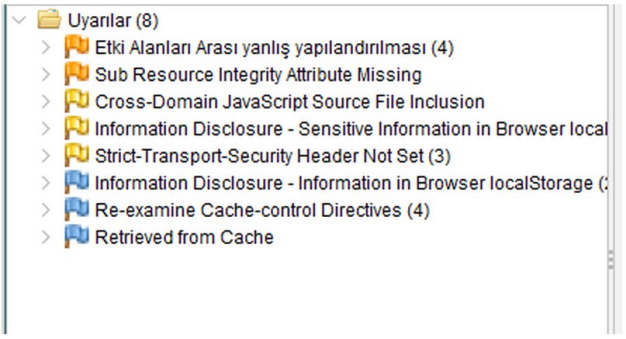
5. OWASP ZAP Önce / Sonra Karşılaştırması

Pasif ZAP taraması önce GitHub Pages üzerindeki eski yayın üzerinde, ardından güvenlik başlıklarının etkin olduğu Cloudflare Pages final yayını üzerinde gerçekleştirilmiştir.

ÖNCE - GitHub Pages: 12 uyarı



SONRA - Cloudflare Pages: 8 uyarı



Şekil 4. OWASP ZAP: önce 12 uyarı, sonra 8 uyarı.

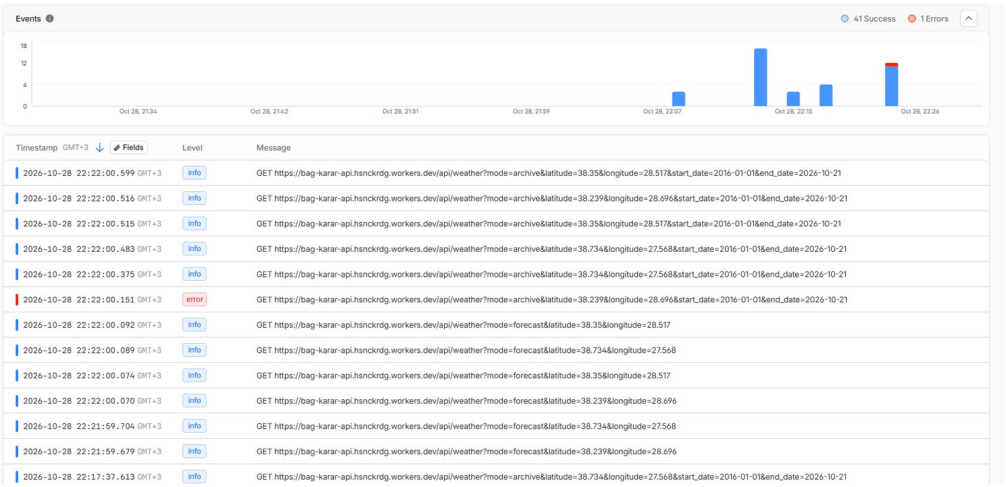
İyileştirme sonrası toplam uyarı sayısı 12'den 8'e düşmüştür. Özellikle Content Security Policy Header Not Set, Missing Anti-clickjacking Header ve X-Content-Type-Options Header Missing uyarıları final Pages yayını için kaldırılmıştır.

Kalan bulguların önemli bir kısmı harici JavaScript kaynağı, localStorage ve cache davranışı gibi düşük seviyeli veya bilgilendirme niteliğindeki kontrollerdir. Ana Pages yanıtındaki temel HTTP güvenlik başlıkları A+ test sonuçlarıyla ayrıca doğrulanmıştır.

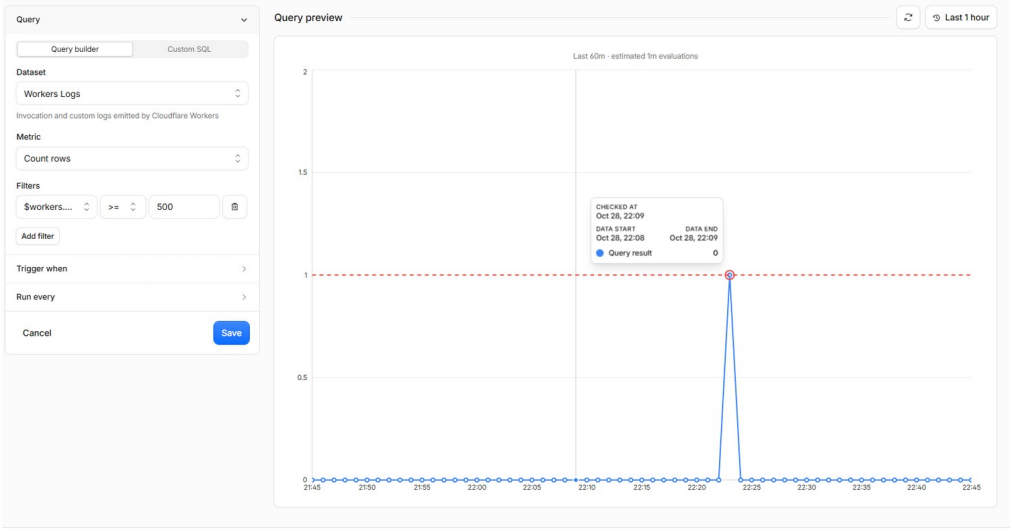
6. Loglama, 5xx Alarmı ve Maliyet Kontrolü

Cloudflare Workers Observability etkinleştirilmiştir. Gerçek API çağrıları zaman damgası ve endpoint bilgisiyle izlenmektedir. Ayrıca 5xx hataları için threshold monitor ve beklenmeyen ücretli kullanım için Billing budget alert oluşturulmuştur.

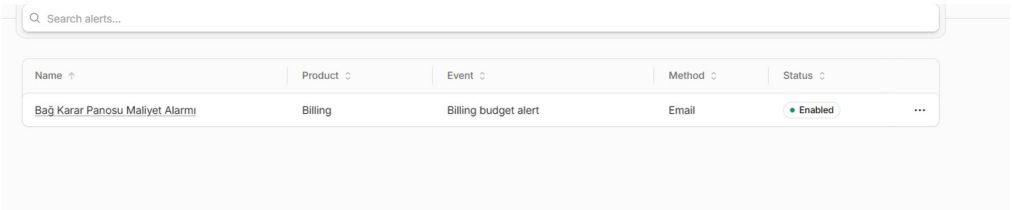
A) Workers Observability: gerçek API logları



B) 5xx hata monitorü: eşik >= 1



C) Billing budget alert: Enabled

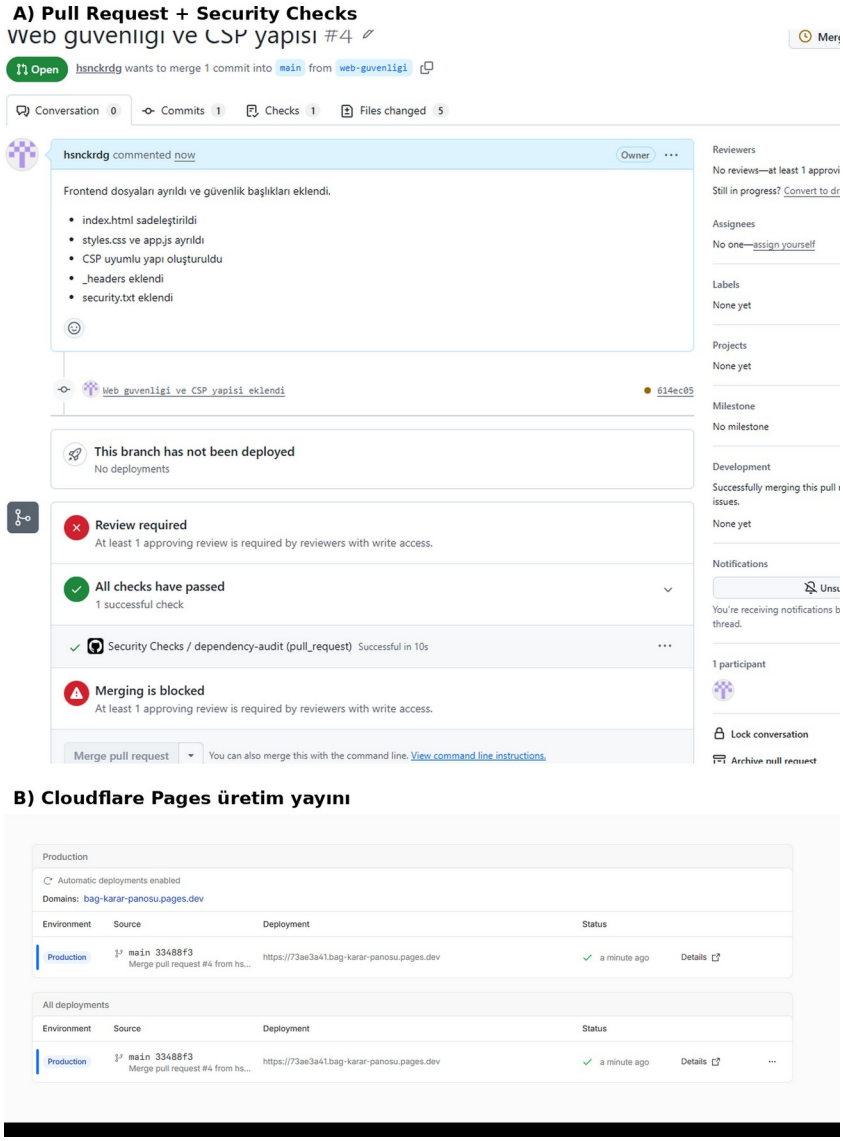


Şekil 5. Worker logları, 5xx monitorü ve maliyet alarmı kanıtları.

5xx alarmı, HTTP response status >= 500 ve Count >= 1 koşuluyla çalışır. Maliyet alarmı e-posta yöntemiyle Enabled durumdadır. Projenin hedef maliyeti 0 TL'dir; 1 USD eşiği yalnızca ücretli kullanım başlarsa erken uyarı almak için seçilmiştir.

7. GitHub, CI/CD ve Infrastructure as Code

Repository üzerinde pull request akışı, branch protection, minimum GitHub Actions izinleri, Dependabot, Secret Protection ve Push Protection etkinleştirilmiştir. Güvenlik workflow'u dependency audit çalıştırmakta ve Actions için contents: read izni kullanılmaktadır.



Şekil 6. Pull Request güvenlik kontrolü ve Cloudflare Pages üretim yayını.

7.1 IaC ve Olay Müdahalesi

Cloudflare Worker yapılandırması wrangler.toml ile sürüm kontrolü altında tutulmaktadır. Dosyada Worker ana dosyası, observability ve RATE_LIMITER binding'i tanımlıdır. Secret/API anahtarı sızıntısı için hazırlanan runbook; tespit, anahtarın iptali, yenilenmesi, log incelemesi, Git geçmişi temizliği ve gerekli bildirimi kapsar.

8. Sonuç

Bağ Karar Panosu; Cloudflare Pages + Worker mimarisi, koordinat allowlist, IP rate limit, 30 dakikalık cache, web güvenlik başlıkları, GitHub güvenlik kontrolleri, loglama ve alarmlar ile korunmuştur. Testlerde 200 isteğin 169'u 429 ile engellenmiş, yetkisiz koordinat 403 ile reddedilmiş ve cache MISS→HIT davranışı doğrulanmıştır. SecurityHeaders ve MDN testlerinde A+ elde edilmiş, ZAP uyarıları 12'den 8'e düşürülmüştür. Sonuç olarak proje, 0 TL hedef maliyetle izlenebilir ve temel kötüye kullanım senaryolarına karşı kontrollü bir bulut altyapısına taşınmıştır.